

Отчёт по выполнению 4-ого этапа индивидуального проекта

Дисциплина: Основы информационной безопасности

Верниковская Екатерина Андреевна

Содержание

1	Цель работы	5
2	Задание	6
3	Выполнение 4-ого этапа индивидуального проекта	7
3.1	Выполнение основных действий	7
3.2	Анализ результатов сканирования	10
4	Выводы	12
5	Список литературы	13

Список иллюстраций

3.1	Запуск mysql и apache2	7
3.2	Запуск DVWA	8
3.3	Запуск nikto	8
3.4	Сканирование веб-приложения по полному URL	9
3.5	Сканирование веб-приложения по адресу хоста и адресу порта	9

Список таблиц

1 Цель работы

Научиться тестированию веб-приложений с помощью сканера nikto.

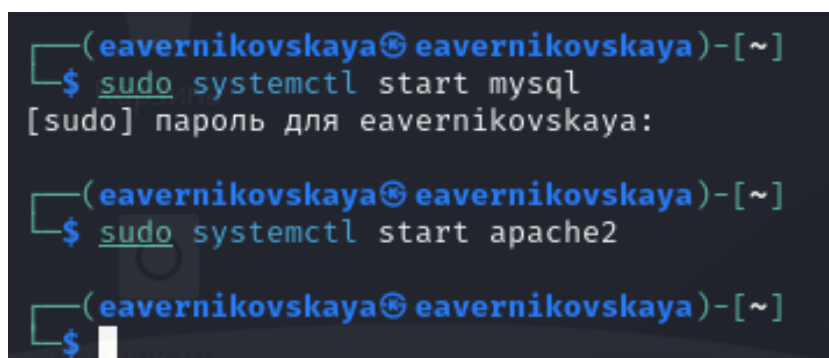
2 Задание

1. Использовать сканер nikto

3 Выполнение 4-ого этапа индивидуального проекта

3.1 Выполнение основных действий

Чтобы работать с nikto, надо сначала подготовить веб-приложение, которое мы будем сканировать. Это будет DVWA. Запустим mysql и apache2: *sudo systemctl start mysql* и *sudo systemctl start apache2* (рис. 3.1)



```
(eavernikovskaya@eavernikovskaya)-[~]  
$ sudo systemctl start mysql  
[sudo] пароль для eavernikovskaya:  
  
(eavernikovskaya@eavernikovskaya)-[~]  
$ sudo systemctl start apache2  
  
(eavernikovskaya@eavernikovskaya)-[~]  
$
```

Рис. 3.1: Запуск mysql и apache2

Далее введём в адресной строке браузера адрес DVWA и перейдём в режим уровня безопасности. Поставим минимальный уровень безопасности “Low” (рис. 3.2)

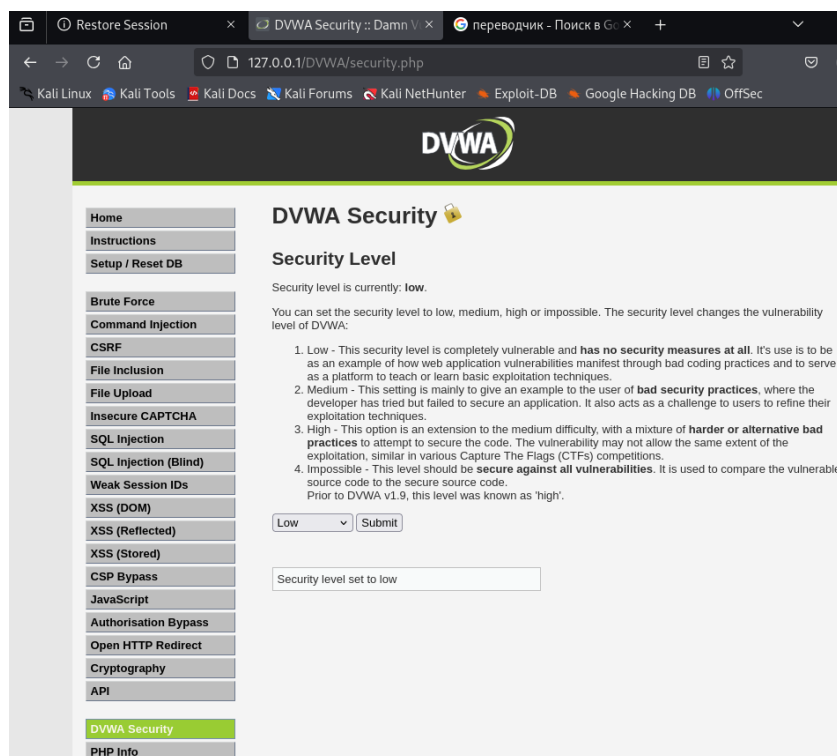


Рис. 3.2: Запуск DVWA

Далее запустим nikto (рис. 3.3)

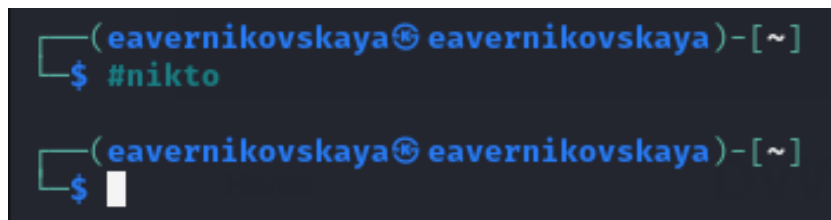


Рис. 3.3: Запуск nikto

Проверить веб-приложение можно введя его полный URL. Просканируем веб-приложение таким образом введя команду `nikto -h http://127.0.0.1/DVWA/` (рис. 3.4)


```

(eavernikovskaya@eavernikovskaya)~$
$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2025-05-02 13:42:31 (GMT3)

+ Server: Apache/2.4.62 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-E all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET .
+ /DVWA///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aaK20aaK27cat%20/etc/hosts: Some D-Link router remote command execution.
+ /DVWA/shell?cat=/etc/hosts: A backdoor was identified.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ 8074 requests: 0 error(s) and 26 item(s) reported on remote host
+ End Time: 2025-05-02 13:43:03 (GMT3) (32 seconds)

```

Рис. 3.4: Сканирование веб-приложения по полному URL

Проверить веб-приложение можно также введя адрес хоста и адрес порта. Про-сканируем веб-приложение таким образом введя команду *nikto -h 127.0.0.1 -p 80* (рис. 3.5)

```

(eavernikovskaya@eavernikovskaya)~$
$ nikto -h 127.0.0.1 -p 80
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Start Time: 2025-05-02 13:45:11 (GMT3)

+ Server: Apache/2.4.62 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 62e677e20b79f, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET .
+ ///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /assets/mobirise/css/meta.php?filesrc=: A PHP backdoor file manager was found.
+ /login.cgi?cli=aaK20aaK27cat%20/etc/hosts: Some D-Link router remote command execution.
+ /shell?cat=/etc/hosts: A backdoor was identified.
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host
+ End Time: 2025-05-02 13:45:46 (GMT3) (35 seconds)

```

Рис. 3.5: Сканирование веб-приложения по адресу хоста и адресу порта

3.2 Анализ результатов сканирования

1. Отсутствие критических HTTP-заголовков:

- X-Frame-Options: Отсутствует защита от кликджекинга (clickjacking), что позволяет злоумышленнику встраивать страницу в iframe и выполнять действия от имени пользователя.
- X-Content-Type-Options: Не установлен заголовок, что может привести к MIME-sniffing атакам, когда браузер неправильно интерпретирует тип контента.

2. Раскрытие системных файлов:

- Доступ к /etc/hosts: Добавление лишнего / в URL (например, //etc/hosts) позволяет читать системные файлы. Это критическая уязвимость, так как злоумышленник может получить доступ к конфиденциальной информации.
- Раскрытие Apache-информации: Доступ к /server-status может предоставить злоумышленнику детали о сервере и его активности.

3. PHP-бэкдоры и файловые менеджеры:

- Обнаружены подозрительные PHP-файлы (например, server.php, meta.php), которые могут быть бэкдорами или файловыми менеджерами. Примеры:
 - /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts
 - /assets/mobirise/css/meta.php?filesrc=
 - /shell?cat=/etc/hosts
- Эти файлы позволяют злоумышленнику читать и, возможно, изменять файлы на сервере.

Backdoor — вредоносная программа, а иногда намеренно оставленная лазейка в коде легальной программы, которая предоставляет доступ к устройству для

несанкционированных действий. Бэкдор в точности соответствует своему названию (от англ. back door — «черный ход»): скрытно впускает злоумышленника в систему, наделяя правами администратора.

4. Уязвимости в директориях:

- Индексация директорий: Найдены открытые директории (/DVWA/config/, /DVWA/database/, /DVWA/docs/), что позволяет злоумышленнику просматривать их содержимое без аутентификации.
- Git-репозиторий: Обнаружены файлы .git/index, .git/HEAD, .git/config, что может привести к утечке исходного кода, если репозиторий не защищен.

5. Уязвимости в CMS (WordPress):

- Найдены пути, связанные с WordPress (например, /wordpress/wp-includes/...), что указывает на возможное использование устаревших или уязвимых версий плагинов/тем.

6. Уязвимости в маршрутизаторах:

- /login.cgi?cli=aa%20aa%22cat%20/etc/hosts: Уязвимость, связанная с D-Link router, позволяющая выполнять удаленные команды

4 Выводы

В ходе выполнения 4-ого этапа индивидуального проекта мы научились использовать сканер nikto для тестирования веб-приложений.

